On the Forgery of Cicada 3301 PGP Signatures via SHA-1 Collision Attacks

Kaoru Aguilera Katayama

March 26, 2026

Abstract

We present a critical observation regarding the cryptographic integrity of communications attributed to Cicada 3301, the anonymous organization known for publishing complex cryptographic puzzles between 2012 and 2017. All verified Cicada 3301 PGP-signed messages employed SHA-1 as the digest algorithm (`Hash: SHA1`). Following the publication of the SHAttered attack by Stevens et al. (2017), which demonstrated practical chosen-prefix collision attacks against SHA-1, the authenticity guarantees of Cicada 3301's PGP signature scheme are fundamentally compromised. We argue that any future communication bearing the Cicada 3301 PGP signature **cannot be trusted** as authentic, as the signature is now practically forgeable. Notably, the final verified Cicada 3301 communication coincides temporally with the disclosure of SHAttered, suggesting possible awareness by the organization itself.

1 Introduction

Cicada 3301 emerged in January 2012, posting cryptographic puzzles across multiple platforms and media. A defining feature of their operational security was the use of PGP-signed messages to authenticate communications. All such messages included the header:

```
-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA1
```

This explicitly indicates the use of SHA-1 (Secure Hash Algorithm 1) as the message digest function within the OpenPGP signature framework (RFC 4880 [3]). The Cicada 3301 public key (Key ID: `7A35090F`) was distributed to allow followers to verify message authenticity.

The last known authenticated message from Cicada 3301 was posted on April 2017. In February 2017, Stevens et al. at Google Research and CWI Amsterdam published *SHAttered* [1], demonstrating the first practical identical-prefix collision attack against SHA-1 at an estimated cost of $110,000 in cloud computing resources.

This temporal coincidence raises a fundamental question: *can any future Cicada 3301 PGP-signed message be considered authentic?*

2 Background

2.1 PGP Signature Mechanism

In the OpenPGP standard, a message signature is computed as:

$$\sigma = \mathcal{S}_{sk}\left(\text{SHA-1}(m \| \text{metadata})\right) \tag{1}$$

where $\mathcal{S}_{sk}$ denotes the signing operation with private key sk, and m is the plaintext message. The verifier checks:

$$\mathcal{V}_{pk}(\sigma) \stackrel{?}{=} \text{SHA-1}(m \| \text{metadata}) \tag{2}$$

The security of this scheme relies on **two** assumptions: (1) the infeasibility of recovering sk from pk, and (2) the collision resistance of the hash function. If either is broken, the scheme fails.

2.2 SHA-1 Collision Attacks

The SHAttered attack [1] demonstrated a practical collision: two distinct messages $m_1 \neq m_2$ such that $\text{SHA-1}(m_1) = \text{SHA-1}(m_2)$, requiring $2^{63.1}$ computations—100,000× faster than brute force.

Critically, Leurent and Peyrin (2020) [2] subsequently demonstrated *chosen-prefix* collision attacks against SHA-1 (SHA-mbles), reducing the practical cost to approximately $45,000. Chosen-prefix collisions are **directly applicable** to PGP signature forgery, as demonstrated by their creation of a PGP key with a colliding fingerprint.

3 The Vulnerability

3.1 Attack Model

An adversary seeks to produce a message m' with a valid Cicada 3301 PGP signature σ' such that verification succeeds under the known public key, **without possessing the private key**.

The attack proceeds as follows:

1. Obtain a legitimately signed message (m, σ) from Cicada 3301's public archive.
2. Using chosen-prefix collision techniques [2], construct $m' \neq m$ such that:

$$\text{SHA-1}(m' \| \text{metadata}') = \text{SHA-1}(m \| \text{metadata}) \tag{3}$$

3. The original signature σ now validates m', or a new key with a colliding fingerprint can be substituted entirely.

3.2 Feasibility Assessment

Attack	Year	Est. Cost
SHAttered (identical-prefix)	2017	$110,000
SHA-mbles (chosen-prefix)	2020	$45,000
Projected (2025)	2025	<$10,000

Table 1: Decreasing cost of SHA-1 collision attacks.

The cost is well within the budget of state actors, corporations, and even well-funded individuals. Moore's law and cloud computing price reductions continue to lower this barrier. As of 2025, such an attack is **trivially affordable**.

3.3 Temporal Coincidence

The fact that Cicada 3301's last communication (April 2017) occurred within weeks of SHAttered's publication (February 23, 2017) is highly suggestive. Two interpretations arise:

1. **Awareness hypothesis:** Cicada 3301, demonstrably sophisticated in cryptography, recognized that their authentication mechanism was irrevocably compromised and ceased communications.
2. **Coincidence hypothesis:** The cessation is unrelated.

Given the organization's deep cryptographic expertise, hypothesis (1) is parsimonious.

4 Implications

4.1 Untrusted Future Messages

Any message purportedly from Cicada 3301 appearing after 2017—even if bearing a valid PGP signature under key `7A35090F` with `Hash: SHA1`—**must be considered unverifiable and potentially forged**. The cryptographic chain of trust is broken at the hash function layer.

4.2 Historical Message Integrity

Messages signed *before* the practical availability of collision attacks (pre-2017) retain a degree of authenticity, as no adversary could have feasibly produced collisions at the time of signing. However, this is a temporal argument, not a cryptographic one; retroactive forgery of "historical" messages with backdated timestamps remains possible.

4.3 No Remediation Path

Unlike an active organization that could rotate keys and upgrade to SHA-256 or SHA-3, Cicada 3301's anonymity and silence since 2017 preclude any key migration. The identity is **permanently compromised** unless a new authentication channel is established through means independent of the existing PGP infrastructure.

5 Conclusion

The Cicada 3301 PGP identity, anchored to SHA-1 via its signing configuration, is cryptographically defunct. The SHAttered and SHA-mbles attacks render signature forgery practical and increasingly inexpensive. We conclude:

1. **No future Cicada 3301 signed message can be authenticated.**
2. The 2017 cessation of communications likely reflects the organization's own recognition of this compromise.
3. Any party claiming to be Cicada 3301 using the original PGP key and SHA-1 signatures should be treated with extreme skepticism.

The case of Cicada 3301 serves as a stark reminder: cryptographic identity is only as durable as its weakest

primitive. SHA-1's deprecation is not merely a theoretical concern—it has real-world consequences for authentication systems that fail to undergo algorithm agility and key rotation.

References

[1] M. Stevens, E. Bursztein, P. Karpman, A. Albertini, and Y. Markov, "The first collision for full SHA-1," in *Advances in Cryptology – CRYPTO 2017*, Springer, 2017, pp. 570–596.

[2] G. Leurent and T. Peyrin, "SHA-1 is a Shambles: First Chosen-Prefix Collision on SHA-1 and Application to the PGP Web of Trust," in *USENIX Security Symposium*, 2020.

[3] J. Callas, L. Donnerhacke, H. Finney, D. Shaw, and R. Thayer, "OpenPGP Message Format," RFC 4880, IETF, November 2007.

[4] X. Wang, Y. L. Yin, and H. Yu, "Finding Collisions in the Full SHA-1," in *Advances in Cryptology – CRYPTO 2005*, Springer, 2005, pp. 17–36.

[5] National Institute of Standards and Technology, "Transitioning the Use of Cryptographic Algorithms and Key Lengths," NIST SP 800-131A Rev. 1, 2015.